

REPORT TECNICO: ESERCIZIO ARCHITETTURA DI RETE E-COMMERCE

1. Azioni Preventive (SQLi e XSS)

Per difendere l'applicazione da attacchi **SQL Injection (SQLi)** e **Cross-Site Scripting (XSS)**, l'azione preventiva più efficace è l'inserimento di un **WAF (Web Application Firewall)**.

- **Descrizione:** Il WAF analizza il traffico HTTP/HTTPS in entrata e blocca le stringhe di codice malevole prima che raggiungano il server e-commerce.
- **Modifica alla figura:** Nello schema, dovresti inserire un nuovo blocco tra il **Firewall** e il **Server E-commerce** (oppure integrato nel firewall se di nuova generazione). Il "Flusso Rosso" dell'attaccante deve fermarsi sul WAF, mentre il "Flusso Giallo" dell'utente prosegue.

2. Impatti sul Business (Analisi DDoS)

In caso di un attacco **DDoS** che rende il servizio indisponibile per 10 minuti, il calcolo del danno economico è il seguente:

- **Dati:** * Durata disservizio: **10 minuti**
 - Perdita media al minuto: **1.500 €**
- **Calcolo Impatto:**

$$10 \text{ min} \times 1.500 \text{ €/min} = 15.000 \text{ €}$$

- **Valutazione preventiva:** Per mitigare questo rischio si consiglia l'adozione di un servizio di **DDoS Protection** (come Cloudflare o AWS Shield) che filtra il traffico massivo a livello di rete prima che saturi la banda del firewall aziendale.

3. Response (Contenimento Malware)

La priorità è impedire la propagazione del malware dal server compromesso verso la rete interna, ignorando per ora l'accesso dell'attaccante.

- **Soluzione Proposta:** Bisogna agire sulle policy del firewall per **eliminare il "Flusso Blu"**. Si impone una regola di "Deny All" (Blocco Totale) per ogni connessione originata dalla DMZ verso la Rete Interna.
- **Modifica alla figura:** Nello schema, la freccia blu che va dalla DMZ alla Rete Interna deve essere cancellata o sbarrata con una **"X" rossa**, indicando che il traffico in quella direzione è ora proibito.

4. Soluzione Completa (Unione punti 1 e 3)

Il disegno finale unificato deve mostrare:

1. Il **WAF** posizionato davanti al server e-commerce (protezione preventiva).
2. L'assenza del **Flusso Blu** verso la rete interna (isolamento della minaccia).

3. Il flusso legittimo (Giallo) che attraversa Firewall e WAF per arrivare al server.

5. Modifica Infrastrutturale "Aggressiva"

Per una protezione definitiva che integri anche la difesa DDoS (punto 2), la modifica più aggressiva consiste nel:

- **Spostamento dell'infrastruttura su Cloud:** Utilizzare una struttura a bilanciatori di carico (Load Balancer) distribuiti su più zone.
- **Air-Gap Logico:** Separare fisicamente i database critici dalla rete degli sviluppatori, rendendoli raggiungibili solo tramite un "Bastion Host" con autenticazione a due fattori (MFA), eliminando qualsiasi fiducia implicita tra i segmenti di rete.